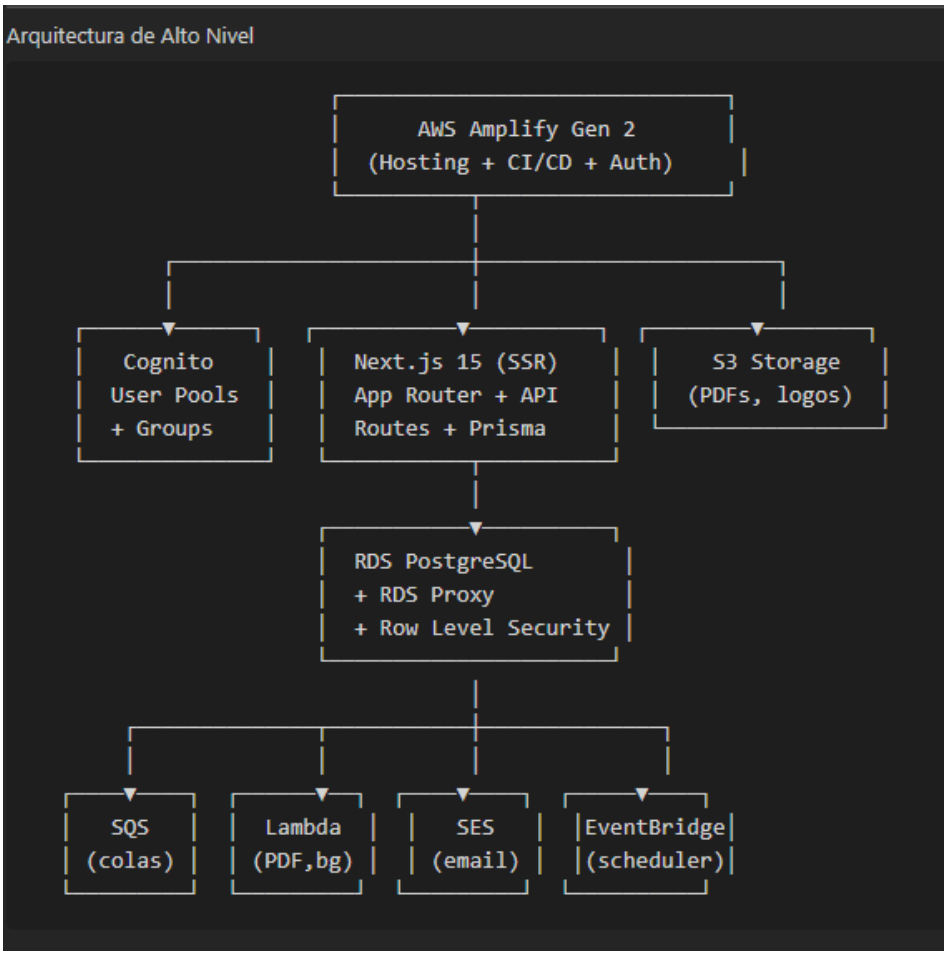
Planificación Inicial de NEXO ERP

NexoERP es un ERP modular web multi-tenant construido con **Next.js 15 (App Router) + Prisma + PostgreSQL**, desplegado en **AWS Amplify Gen 2** con servicios complementarios AWS. El sistema sigue una arquitectura de **shared schema con company_id + Row-Level Security** para multi-tenencia. El MVP prioriza: **Core (auth, empresas, permisos) → Contabilidad (plan de cuentas NIIF) → Facturación (CAI/SAR Honduras)**. El namespace del monorepo es @nexoerp/* con Conventional Commits + Changesets para versionado. Se usa v0.dev + Figma para diseño de interfaces, Notion para gestión de tareas, y MCPs (GitHub, Context7, Notion, PostgreSQL) para asistencia por IA.

Arquitectura de Alto Nivel



Stack Tecnológico

Capa	Tecnología	Versión objetivo
Frontend	Next.js (App Router) + React 19	15.x
UI Components	shadcn/ui + Radix UI + Tailwind CSS 4	latest
Tablas	TanStack Table v8	8.x
Gráficos	Recharts o Tremor	latest
State Management	Zustand (global) + TanStack Query (server state)	5.x / 5.x
Forms	React Hook Form + Zod (validación)	7.x / 3.x
Hosting/CI-CD	AWS Amplify Gen 2	Gen 2
Auth	AWS Cognito (via Amplify)	—
API Layer	Next.js API Routes (Route Handlers)	—
ORM	Prisma (con Client Extensions)	6.x
Base de datos	RDS PostgreSQL + RDS Proxy	16.x
Connection pool	RDS Proxy (o Prisma Accelerate)	—
File Storage	S3 via Amplify Storage	—
PDF Generation	Lambda + @sparticuz/chromium + Puppeteer	—
Excel Export	exceljs	4.x
Email	AWS SES	—
Background Jobs	SQS + Lambda	—
Scheduled Tasks	EventBridge Scheduler	—
Monitoreo	CloudWatch + Sentry (frontend)	—
CDN	CloudFront (automático via Amplify)	—
Secrets	AWS Secrets Manager	—
Región AWS	us-east-1 (Virginia)	—

FASE 0: Fundación del Proyecto (Semana 1-2)

1. **Inicializar monorepo Next.js + Amplify Gen 2**
    - npx create-next-app@latest nexoerp --typescript --tailwind --app --src-dir
    - npx ampx configure → configurar Amplify Gen 2
    - Configurar amplify/backend.ts, amplify/auth/resource.ts (Cognito con grupo admin, manager, seller, auditor y custom attribute company_id)
    - Configurar amplify/storage/resource.ts (bucket para documentos)
2. **Configurar Prisma + PostgreSQL**
    - npm install prisma @prisma/client → inicializar con multi-file schema (feature flag prismaSchemaFolder)
    - Crear prisma/schema/core.prisma con modelos: Company, User, Role, Permission, RolePermission, UserRole, Module, CompanyModule, Menu, AuditLog
    - Configurar RLS en PostgreSQL: policies por company_id en todas las tablas de negocio
    - Crear Prisma Client Extension para multi-tenancy (@nexoerp/prisma-tenant)
3. **Configurar infraestructura de desarrollo**
    - Changesets: npx changeset init → .changeset/config.json
    - Conventional Commits: commitlint + husky (pre-commit hooks)
    - ESLint + Prettier con reglas TypeScript strict
    - Vitest para unit/integration tests
    - Playwright para E2E
    - CHANGELOG.md con formato Keep a Changelog
    - .env.example con todas las variables necesarias
4. **Configurar ambientes**

- **Desarrollo**: Amplify Sandbox (1 por developer) + RDS local (Docker PostgreSQL)
- **Staging**: Amplify branch staging → auto-deploy → RDS staging instance
- **Producción**: Amplify branch main → auto-deploy → RDS production instance
- Configurar Secrets Manager para cada ambiente (DB credentials, SES config, etc.)

5. **Configurar MCPs y herramientas**
    - GitHub MCP: repo nexoerp/nexoerp, branch protection rules, PR templates
    - Context7 MCP: para documentación actualizada de Next.js 15, Prisma 6, Amplify Gen 2
    - Notion MCP: crear workspace con boards: Backlog, Sprint, In Progress, Review, Done
    - PostgreSQL MCP: conexión al DB de desarrollo para inspección de schema

FASE 1: Core System (Semana 3-6)

6. **Módulo de Autenticación y Seguridad**
    - Login/Register con Cognito (email + password)
    - Middleware Next.js: verificar JWT, extraer company_id, redirigir si no autenticado
    - lib/auth/session.ts: getCurrentUser(), getCurrentCompany(), hasPermission()
    - Página de selección de empresa (si usuario pertenece a varias)
    - Recuperación de contraseña y confirmación de email
7. **Gestión de Empresas**
    - CRUD de empresas: nombre, RTN (Registro Tributario Nacional), dirección, logo (S3), moneda base (HNL), monedas secundarias (USD)
    - Configuración fiscal: régimen tributario, CAI activos, puntos de emisión

- Tasas de cambio: tabla ExchangeRate con fecha, moneda origen, moneda destino, tasa

8. **Gestión de Usuarios y Roles (Permisos Granulares)**
    - CRUD de usuarios vinculados a empresa
    - Sistema de roles: definir roles con permisos por módulo y acción (crear, leer, editar, eliminar)
    - Tabla Permission: module (invoicing, accounting...) + action (create, read, update, delete) + scope (own, all)
    - Menú dinámico: sidebar renderiza solo módulos/menús a los que el usuario tiene acceso
    - Sincronización Cognito groups ↔ roles del sistema
9. **Sistema de Módulos Activables**
    - Tabla Module: id, name, slug, description, is_active
    - Tabla CompanyModule: company_id, module_id, activated_at, config (JSON)
    - API: activar/desactivar módulos por empresa
    - Frontend: pantalla de "Módulos disponibles" estilo marketplace
10. **Auditoría Transversal**
    - Prisma Client Extension que intercepta create, update, delete en todos los modelos → escribe en AuditLog
    - Campos: entity, entity_id, action, old_values (JSON), new_values (JSON), user_id, company_id, timestamp, ip_address
    - Widget <AuditTrail entityType="invoice" entityId={id} /> reutilizable en todos los módulos
11. **Layout Dashboard**
    - Sidebar colapsable con navegación por módulos (iconos + texto)
    - Topbar con: búsqueda global (Command Palette ⌘K), selector de empresa, notificaciones, perfil
    - Breadcrumbs automáticos

- Responsive (sidebar → bottom nav en mobile)
- Dark mode toggle (Tailwind CSS dark: prefix)

FASE 2: Contabilidad + Contactos (Semana 7-12)

12. **Módulo de Contactos**
    - Modelo Contact: tipo (cliente/proveedor/ambos), nombre, RTN, dirección, teléfonos, emails, sitio web
    - Modelo ContactAddress: múltiples direcciones por contacto (facturación, envío)
    - Modelo PaymentTerms: neto 30, neto 60, contado, personalizable
    - Vista lista con filtros + vista detalle con panel lateral
    - Importación masiva desde Excel
13. **Contabilidad — Plan de Cuentas**
    - Modelo Account: código, nombre, tipo (activo, pasivo, capital, ingreso, costo, gasto), naturaleza (deudora/acreedora), padre_id (jerárquico), is_reconcilable, currency_id
    - Seed con plan de cuentas base Honduras (NIIF para PYMEs): ~200 cuentas predeterminadas
    - Vista de árbol jerárquico con expand/collapse
    - CRUD con validación de códigos únicos
14. **Contabilidad — Períodos y Años Fiscales**
    - Modelo FiscalYear: fecha inicio, fecha fin, estado (abierto/cerrado)
    - Modelo FiscalPeriod: mes dentro del año fiscal
    - Cierre de período: impide nuevos asientos en períodos cerrados
    - Honduras: año fiscal = enero a diciembre
15. **Contabilidad — Asientos Contables**

- Modelo JournalEntry: número secuencial, fecha, diario (ventas, compras, general, banco), estado (borrador/publicado/cancelado), description
- Modelo JournalEntryLine: cuenta_id, debe, haber, contacto_id, referencia
- Validación: debe = haber (partida doble)
- Asientos automáticos desde facturación (hooks)
- Vista lista + formulario de creación con líneas dinámicas

16. **Contabilidad — Reportes**
    - Balance General (Estado de Situación Financiera)
    - Estado de Resultados
    - Balance de Comprobación
    - Libro Mayor por cuenta
    - Libro Diario
    - Exportación PDF + Excel para todos
17. **Multimoneda**
    - Tabla Currency: código ISO, nombre, símbolo, decimales
    - Tabla ExchangeRate: fecha, moneda_origen, moneda_destino, tasa
    - Seed: HNL (Lempira) + USD preconfigurados
    - Utility convertCurrency(amount, from, to, date): busca tasa vigente
    - Asientos contables registran montos en moneda original + moneda base
    - Diferencial cambiario automático

FASE 3: Facturación Honduras (Semana 13-18)

18. **Configuración Fiscal Honduras**
    - Modelo TaxRate: nombre (ISV 15%, ISV 18%, Exento), porcentaje, tipo (ventas/compras/ambos), cuenta_contable_id

- Modelo CAI: código, rango_inicio, rango_fin, fecha_vencimiento, punto_emisión, tipo_documento, correlativo_actual, company_id
- Modelo EmissionPoint: código (000-001), nombre del establecimiento
- Validación automática: alerta cuando CAI está por vencer o rango agotándose (< 10% restante)

19. **Facturación de Ventas**
    - Modelo Invoice: número_fiscal (formato SAR), contacto_id, fecha, fecha_vencimiento, estado (borrador/publicado/pagado/cancelado), tipo_documento (factura/crédito_fiscal/nota_crédito/nota_débito/exportación), cai_id, moneda_id, tasa_cambio, subtotal, impuestos, total
    - Modelo InvoiceLine: producto, descripción, cantidad, precio_unitario, descuento, tax_ids, subtotal_línea
    - Número fiscal auto-generado desde el CAI activo: PPP-PPP-TT-NNNNNNNN
    - Impresión conforme requisitos SAR: en el PDF debe aparecer CAI, rango autorizado, fecha límite, RTN del emisor/receptor
    - Flujo: Borrador → Vista previa → Publicar (incrementa correlativo CAI, genera asiento contable automático) → Enviar por email
20. **Facturas de Proveedor**
    - Modelo BillVendor (o extensión de Invoice con direction: inbound): similar a factura pero recibida del proveedor
    - Registro del ISV como crédito fiscal para deducciones
    - Vinculación futura con órdenes de compra (Fase 4)
    - Generación de asiento contable automático (gasto/inventario → cuenta por pagar)
21. **Notas de Crédito y Débito**
    - Vinculadas a una factura original
    - Ajustan saldos en contabilidad automáticamente
    - Requieren su propio rango CAI

22. **Libro de Ventas / Libro de Compras**
    - Reporte mensual de todas las facturas emitidas (ventas) y recibidas (compras)
    - Formato compatible con declaración DET del SAR
    - Columnas: fecha, tipo doc, número, RTN cliente/proveedor, gravado 15%, gravado 18%, exento, ISV
    - Exportación: PDF + Excel + CSV (para DET)
23. **Generación de PDF (Facturas)**
    - Lambda function con Puppeteer + @sparticuz/chromium
    - Template HTML/Handlebars con diseño profesional
    - Datos del SAR embebidos: CAI, rango, fecha límite, RTN
    - Almacenamiento en S3, URL prefirmada para descarga
    - Trigger: al publicar factura → SQS → Lambda → S3 → actualizar URL en DB
24. **Reporting Transversal (PDF + Excel)**
    - Servicio genérico: exportReport(type, filters, format) → SQS → Lambda → S3
    - Para tablas: componente <DataTable> con botones "Exportar PDF" y "Exportar Excel"
    - Para reportes complejos: generación asíncrona con notificación al estar listo
    -

FASE 4: Compras + Ventas/CRM + Inventario (Semana 19-30)

25. **Módulo de Compras**
    - Solicitud de cotización → Orden de compra → Recepción → Factura proveedor
    - Listas de precios por proveedor
    - Aprobaciones (workflow simple: monto > X requiere aprobación de gerente)

26. **Módulo de Ventas y CRM**
    - Pipeline de oportunidades: vista Kanban con fases personalizables (drag & drop)
    - Presupuestos → Pedidos de venta → Factura
    - Informe de cobranzas: facturas pendientes con aging (0-30, 31-60, 61-90, 90+ días)
27. **Módulo de Inventario**
    - Productos: modelo Product con SKU, nombre, categoría, tipo (físico/servicio), unidad de medida
    - Almacenes y ubicaciones: Warehouse → Location (jerárquico)
    - Movimientos de stock: StockMove (entrada, salida, transferencia interna)
    - Valoración: FIFO o Promedio Ponderado (configurable por empresa)
    - Reglas de reabastecimiento: stock mínimo, punto de reorden, cantidad a pedir
    - Trazabilidad por lotes (opcional, activable por empresa)

MCP Servers para configurar:

MCP	Propósito
GitHub MCP	Gestión del repo, PRs, issues, code review
Context7	Docs actualizadas de Next.js 15, Prisma 6, Amplify Gen 2
Notion MCP	Crear/actualizar tareas, consultar sprints, documentar
PostgreSQL MCP	Inspeccionar schema, correr queries de debug, verificar RLS
Figma MCP	Extraer design tokens y specs de componentes
Sequential Thinking	Razonamiento estructurado para decisiones de arquitectura complejas

Sub-Agentes (Roles especializados en prompts):

Sub-Agente	Rol	Cuando usarlo
Architect Agent	Revisa decisiones de arquitectura, patrones de diseño, schema DB, performance	Antes de cada fase nueva, al añadir módulo
QA/Testing Agent	Genera tests unitarios, de integración, E2E. Revisa cobertura.	Después de implementar cada feature
UX/UI Review Agent	Revisa consistencia de interfaz, accesibilidad (a11y), responsive	Al completar cada pantalla
DevOps/Deploy Agent	Revisa configuración de ambientes, CI/CD, seguridad, performance	Al configurar ambientes, antes de release
Planning Agent	Descompone features en tareas, estima esfuerzo, prioriza backlog	Al inicio de cada sprint
Data/Schema Agent	Revisa modelos de datos, migraciones, integridad referencial, índices	Al crear/modificar modelos Prisma

Prompts para Diseño UI

Dashboard Principal:

"Create a modern ERP dashboard layout with: 1) A collapsible sidebar with icon+text navigation grouped by modules (Core, Accounting, Invoicing, Inventory, Sales, Purchases) with active state highlighting, 2) A top bar with global search (Command+K), company selector dropdown, notification bell, and user avatar menu, 3) Main content area showing: 4 KPI cards (revenue, pending invoices, overdue payments, active customers) with trend arrows and sparkline charts, a revenue vs expenses bar chart for the last 12 months, recent invoices table with status badges (draft=gray, published=blue, paid=green, overdue=red), and a quick actions panel. Use shadcn/ui components, Tailwind CSS, neutral palette with indigo-600 accent. Dark mode support. Responsive layout."

Facturación:

"Design an invoice creation form for Honduras fiscal requirements: 1) Header section with auto-generated fiscal number (format: 000-001-01-00000001), CAI code display, date picker, due date, customer search combobox with recent suggestions, 2) Line items table with inline editing: product search, description, quantity (number input), unit price (currency formatted HNL), discount %, tax selector (ISV 15%, ISV 18%, Exempt), line total auto-calculated, add/remove row buttons, 3) Totals panel: subtotal, discount total, ISV 15% amount, ISV 18% amount, total in letters (Spanish), 4) Footer: payment terms selector, internal notes textarea, 5) Action bar: Save Draft, Preview PDF, Publish & Send buttons. Use shadcn/ui, clean professional design."

Contabilidad - Plan de Cuentas:

"Create an interactive chart of accounts tree view: hierarchical expandable list showing account code (bold monospace), account name, type badge (Asset/green, Liability/red, Equity/purple, Income/blue, Expense/orange), balance column right-aligned with currency format, search/filter bar at top, add account button, edit inline on click, drag and drop to reorganize hierarchy. Use shadcn/ui Tree component pattern with Tailwind CSS."

Contactos:

"Design a contacts directory page with: 1) Left panel: search bar + filter chips (All, Customers, Suppliers), scrollable contact list cards showing avatar/initials, name, company, tags. 2) Right panel: selected contact detail view with tabs (General, Addresses, Invoices, Payments, Activity). General tab shows: editable form fields for name, RTN (tax ID), type, email, phone, website, payment terms, credit limit, assigned salesperson. Address tab shows multiple addresses with map preview. Activity tab shows timeline of interactions. Use a master-detail layout with shadcn/ui."

Para Figma (prompts de diseño):

"Design a complete design system for NexoERP, a modern ERP application. Include: color palette (primary indigo, semantic colors for success/warning/error/info), typography scale (Inter font, 6 sizes), spacing scale (4px base), component library (buttons: primary/secondary/ghost/destructive in 3 sizes, inputs with labels and validation states, select/combobox, date picker, data table with sorting/filtering/pagination, stat cards, status badges, sidebar navigation with collapsible groups, modal dialogs, toast notifications, breadcrumbs, tabs). Dark mode variants for all components. 8px grid. Accessible contrast ratios (WCAG AA)."

Ambientes de Desarrollo

Ambiente	Branch	Base de datos	Propósito
Local	cualquiera	Docker PostgreSQL 16	Desarrollo diario
Sandbox	feature/*	Amplify Sandbox (efímero)	Testing de features AWS
Staging	staging	RDS staging instance	QA, demos a clientes
Production	main	RDS production instance	Producción real

Flujo de entrega de código via Git

feature/xxx → PR → staging (auto-deploy) → QA → merge to main → production (auto-deploy)

Changelog y Versionado

- **Formato**: Keep a Changelog + Semantic Versioning
- **Herramienta**: @changesets/cli para gestionar releases
- **Commits**: Conventional Commits obligatorio via commitlint + husky
  - Formato: feat(invoicing): add CAI range validation
  - Scopes: core, auth, contacts, accounting, invoicing, purchasing, sales, i nventory, ui, infra
- **Proceso**: Cada PR incluye un changeset file → al mergear a main, Changesets bot genera PR de release con CHANGELOG actualizado

Verificacion y Testing

1. **Unit Tests**: Vitest para lógica de negocio (cálculos de ISV, validación CAI, conversión de moneda, partida doble). Cobertura mínima objetivo: 80%
2. **Integration Tests**: Vitest + Prisma con DB de test para API routes (CRUD completo, multi-tenant isolation)

3. **E2E Tests**: Playwright para flujos críticos (login → crear factura → publicar → verificar PDF → verificar asiento contable)
4. **Multi-tenant Isolation Test**: Test automatizado que verifica que Company A no puede ver datos de Company B
5. **RLS Verification**: Queries directas a PostgreSQL verificando que RLS bloquea acceso cruzado
6. **Lighthouse**: Performance > 90, Accessibility > 95 en pages principales
7. **Manual**: Flujo completo de facturación con CAI real de prueba del SAR

Servicios AWS Recomendados — Desglose por Fase

Fase	Servicio	Propósito	Costo estimado/mes
0	Amplify Gen 2 Hosting	CI/CD + SSR	~$5-15
0	Cognito	Auth (50K MAU gratis)	$0 inicialmente
0	RDS PostgreSQL (db.t3.micro)	Base de datos	~$15-25
0	S3	Storage archivos	~$1-5
0	Secrets Manager	Credenciales	~$2
1	CloudFront	CDN (incluido con Amplify)	$0
3	Lambda	PDF generation, background	~$0-5
3	SQS	Cola de trabajos	~$0-1
3	SES	Email transaccional	~$1 (1000 emails)
3	RDS Proxy	Connection pooling	~$15
4	EventBridge Scheduler	Tareas programadas	~$1
Total estimado MVP			**~$40-70/mes**

Seguridad AWS para NexoERP — **Análisis Completo**

Capas de Seguridad (Defense in Depth)

```
Internet → CloudFront + WAF → ALB/Amplify → VPC → Security Groups → RDS/Lambda
   |            |                                        |
   |        AWS Shield                              Network ACLs
   |        (DDoS)                                  (Subnet level)
   |
   └── Rate Limiting + Bot Control + Geo-Restriction
```

1. AWS WAF (Web Application Firewall) — Recomendado desde inicio

Característica	Detalle
Integración	Se acopla a CloudFront (que Amplify usa automáticamente)
Protección contra	SQL Injection, XSS, CSRF, request forgery, path traversal
Rate limiting	Limitar requests por IP (ej: max 2000 req/5min) — protege contra brute force
Geo-blocking	Restringir acceso por país (útil: permitir solo Honduras, USA, y países específicos)
Bot control	Detectar y bloquear bots maliciosos
Costo	~$5/mes base + $1/millón de requests evaluados

Para NexoERP específicamente:

- Protege las API routes de Next.js contra inyección SQL (aunque Prisma ya parametriza queries, es una capa adicional)
- Rate limit en endpoints de login para prevenir brute force (complementa Cognito)
- Geo-restriction: dado que los clientes son PYMEs hondureñas, podemos restringir acceso a la región CA/NA y activar alertas para accesos inusuales

2. AWS Shield — Standard gratuito, Advanced opcional

Tier	Protección	Costo
Shield Standard	DDoS L3/L4 automático en CloudFront, ALB, Route 53	**Gratis** (incluido)
Shield Advanced	DDoS avanzado L7, equipo de respuesta 24/7, protección de costos por DDoS	~$3,000/mes (no necesario para MVP)

Recomendación: Shield Standard es suficiente para inicio. Evaluar Advanced cuando el ERP tenga clientes empresariales grandes.

3. Network ACLs (NACLs) — Nivel de subred en VPC

Aspecto	Configuración recomendada
Subred pública	Permitir HTTP/HTTPS (80, 443) entrante. Denegar todo lo demás.
Subred privada (RDS)	Solo permitir tráfico desde la subred de Lambda/Amplify en puerto 5432 (PostgreSQL). **Denegar todo acceso directo desde Internet.**
Subred privada (Lambda)	Solo tráfico saliente a RDS y servicios AWS.
Regla por defecto	DENY ALL — principio de whitelist

4. Security Groups — Firewall a nivel de instancia

Security Group	Inbound	Outbound
SG-Amplify/Lambda	N/A (serverless)	PostgreSQL (5432) a SG-RDS, HTTPS (443) a servicios AWS
SG-RDS	PostgreSQL (5432) **solo** desde SG-Amplify/Lambda	Ninguno (solo respuestas)
SG-RDS-Proxy	PostgreSQL (5432) desde SG-Lambda	PostgreSQL (5432) a SG-RDS

Punto clave: La base de datos RDS **nunca** debe tener IP pública ni acceso directo desde Internet. Solo se accede a través de RDS Proxy desde las funciones Lambda o API routes de Next.js.

5. Seguridad de Datos en Reposo y Tránsito

Capa	Mecanismo	Config
RDS	Encryption at rest (AES-256 via KMS)	Activar al crear instancia
RDS	SSL/TLS en tránsito	sslmode=require en connection string
S3	Server-Side Encryption (SSE-S3 o SSE-KMS)	Activar por defecto en bucket
S3	Block Public Access	Activar las 4 opciones de bloqueo
Cognito	Tokens encriptados, HTTPS obligatorio	Por defecto
Secrets Manager	Encriptación KMS para credenciales	Por defecto
CloudFront	TLS 1.2+ obligatorio, HSTS headers	Configurar en distribution

6. Seguridad de Autenticación (Cognito)

Feature	Configuración	Propósito
Advanced Security	Activar (tiene costo adicional ~$0.05/MAU)	Detección de credenciales comprometidas, adaptive auth
Brute force protection	Max 5 intentos, lockout 15 min	Bloquear ataques de fuerza bruta
MFA	Opcional para admin, TOTP (Google Auth)	Capa extra para roles críticos

Device tracking	Activar	Detectar sesiones desde dispositivos no reconocidos
Password policy	Min 8 chars, mayúscula, número, especial	Contraseñas robustas
Token expiration	Access: 1h, Refresh: 30d, ID: 1h	Minimizar ventana de ataque

7. Seguridad a Nivel de Aplicación

Medida	Implementación	Capa
CSRF Protection	Next.js built-in + SameSite cookies	Frontend/API
XSS Prevention	React auto-escaping + CSP headers	Frontend
SQL Injection	Prisma (queries parametrizadas) + WAF	ORM/Infra
CORS	Whitelist de dominios permitidos en API routes	API
Rate Limiting	WAF + middleware custom en API routes	Infra/API
Input Validation	Zod schemas en todos los endpoints	API
HTTP Security Headers	Helmet-like headers en next.config.ts	Frontend
Content Security Policy	Restringir fuentes de scripts/estilos	Frontend
Audit Logging	Prisma Extension (ya planificado)	DB

Strict-Transport-Security: max-age=63072000; includeSubDomains; preload

X-Content-Type-Options: nosniff

X-Frame-Options: DENY

X-XSS-Protection: 1; mode=block

Referrer-Policy: strict-origin-when-cross-origin

Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'...

Permissions-Policy: camera=(), microphone=(), geolocation=()

8. Monitoreo y Respuesta a Incidentes

Servicio	Propósito	Fase	Costo
CloudTrail	Log de todas las llamadas API a AWS	0	Gratis (1 trail)
CloudWatch Alarms	Alertas por errores 5xx, latencia alta, intentos de login fallidos	1	~$1-3/mes
GuardDuty	Detección de amenazas (comportamiento anómalo, crypto mining, acceso sospechoso)	1	~$4-10/mes
AWS Config	Verificar compliance de configuración (S3 público? RDS sin encryption?)	2	~$2/mes
Security Hub	Dashboard centralizado de postura de seguridad	3	~$1/mes

9. Resumen: Servicios de Seguridad por Fase

Fase	Servicio	Costo/mes	Justificación
0	VPC + NACLs + Security Groups	$0	Arquitectura de red base
0	Shield Standard	$0	DDoS básico (automático)
0	RDS Encryption at rest/transit	$0	Datos financieros encriptados
0	S3 Block Public Access + SSE	$0	Proteger documentos
0	CloudTrail	$0	Auditoría de API AWS
0	Secrets Manager	~$2	Credenciales seguras

1	WAF (en CloudFront)	~$6-10	Protección web L7
1	Cognito Advanced Security	~$3-5	Adaptive auth, credentials check
1	CloudWatch Alarms	~$2	Alertas de incidentes
1	GuardDuty	~$5	Threat detection
2	AWS Config	~$2	Compliance
—	**Total seguridad MVP**	**~$20-25/mes**	